

MANUEL KALI

Manuel d'utilisation — IRON MAN AI sur Kali Linux

L'outil d'audit web s'appelle **IRON MAN AI** et s'utilise sur une machine

Kali Linux : vérifier que tous les outils de sécurité sont présents,

les installer si nécessaire, puis lancer un **audit de sécurité d'un site web**

avec l'ensemble des outils disponibles (nmap, nikto, whatweb, gobuster,

dirsearch, sslscan, nuclei, wafw00f, dnsrecon) et, si vous y êtes

explicitement autorisé, les outils d'attaque sqlmap, xssstrike, commix et hydra.

Une seule commande (`ironman.py`) lance **tout l'audit ensemble** :

tous les outils, l'un après l'autre, **au maximum**, sans limite de temps

d'analyse, et produit **l'audit complet en PDF** (ainsi qu'en JSON et en HTML).

 **Sécurité et éthique.** N'analysez que des sites que **vous possédez**

ou pour lesquels vous disposez d'une **autorisation écrite** du

propriétaire. Le flag `--authorized` est obligatoire : il confirme que

vous comprenez cette règle. Les agissements malveillants sont interdits.

1. Prérequis

- **Python 3.10+** (le cœur est en stdlib, aucune dépendance).
- **Kali Linux** (les outils ci-dessous y sont généralement présents).

- Les outils suivants, installés comme **paquets Kali** :

Outil	Paquet apt	But
nmap	nmap	Découverte des ports/services
nikto	nikto	Scanner de vulnérabilités web
whatweb	whatweb	Détection des technologies
gobuster	gobuster	Énumération de répertoires
dirsearch	dirsearch	Énumération de chemins web
ssllscan	ssllscan	Contrôle TLS/SSL (https)
nuclei	nuclei	Template de vulnérabilités
wafw00f	wafw00f	Détection de WAF
dnsrecon	dnsrecon	Reconnaissance DNS

Et pour le mode **attack** : `sqlmap` , `xsstrike` , `commix` , `hydra` .

2. Vérifier les outils présents avant de lancer (PRÉFLIGHT)

La commande dédiée est `--check` . Elle examine chaque binaire et, s'il en manque un, **affiche la commande exacte à exécuter** pour l'installer.

```
cd /chemin/codescan
uv run python kali_scan.py --check
```

Sortie exemple :

```
=== Préflight IRON MAN AI (Kali) ===
MANQUANT nmap      nmap -> sudo apt-get install -y nmap
MANQUANT nikto     nikto -> sudo apt-get install -y nikto
... (tous les outils manquants listés) ...
5/9 outils présents, 4 manquant(s).
```

On peut vérifier aussi les outils "attack" avec `--check --attack` .

Pour **installer tous les outils manquants en une seule fois**, copiez la commande affichée (elle est construite automatiquement) :

```
sudo apt-get update && sudo apt-get install -y nmap nikto whatweb gobuster dirsearch ss  
# Si vous voulez aussi le mode attack :  
sudo apt-get install -y sqlmap xssstrike commix hydra
```

Le scanner **ne lance plus le scan** s'il manque des outils « web »

essentiels, afin de ne jamais donner un faux sentiment de couverture.

Ajoutez `--allow-missing` si vous voulez tout de même lancer avec les

outils présents (le rapport signale alors les outils manquants).

3. LA commande unique : audit complet en PDF (IRON MAN AI)

Sur Kali, une **seule commande** fait **tout l'audit ensemble** : elle lance **tous les outils les uns après les autres** (web **et** invasifs), **au maximum de leurs capacités, sans limite de temps d'analyse**, avec toutes les autorisations requises, et produit **l'audit complet en PDF** (plus le JSON et le HTML) :

```
uv run python ironman.py --url https://example.com --authorized
```

C'est l'équivalent exact de

```
kali_scan.py --url ... --authorized --full --attack --pdf . Concrètement,
```

le drapeau `--full` (alias `--maximal`) :

- active `--attack` (sqlmap, xssstrike, commix, hydra) ;
- **supprime les timeouts** : chaque outil tourne jusqu'à son terme ;
- utilise la **wordlist complète** (plus de plafond de 200 mots) ;
- pousse les outils au maximum : `nmap -sV -Pn -p- -sC` (tous les ports, scripts), `sqlmap --level 3 --risk 3`, threads élevés ;

- **produit automatiquement le PDF** de l'audit complet, à côté des rapports JSON et HTML — écrits par défaut dans le **dossier central** `rapports/` (`rapports/audit_web_AAAAMMJJ_HHMMSS.json` + `.html` + `.pdf`, horodatés). `-o /chemin/rapport` pour écrire ailleurs.

```
uv run python ironman.py --url https://example.com --authorized
```

Le PDF est généré **100 % en bibliothèque standard** (aucun navigateur requis) : en-tête, score global, synthèse par sévérité, résultat par outil, préflight et détail complet des relevés groupés par outil.

Version **raisonnable** (outils web uniquement, timeouts courts, wordlist bornée, **sans** PDF) : utilisez `kali_scan.py --url ... --authorized`

(voir section 4). Vous pouvez aussi restreindre `ironman.py` avec

```
--tools , --exclude ou --dry-run , et vérifier d'abord avec --check .
```

4. Lancer un scan web (toutes les failles)

Le scan lance **tous les outils disponibles** (palier « web », non invasif) contre la cible, avec **timeouts limites et wordlists réduites** pour rester raisonnable, puis **réunit les failles trouvées**.

```
# Cible http
uv run python kali_scan.py --url http://example.com --authorized

# Cible https (sslscan est alors actif)
uv run python kali_scan.py --url https://shop.example.com --authorized

# Avec un rapport (+ PDF de l'audit complet si --pdf)
uv run python kali_scan.py --url https://example.com --authorized \
  --output rapport_web.html
uv run python kali_scan.py --url https://example.com --authorized \
  --output rapport_web.json
uv run python kali_scan.py --url https://example.com --authorized \
  --output rapport_web.html --pdf
```

Un **serveur de test local vulnérable** est fourni (cible sûre pour s'initier) :

```
uv run python examples/vuln_server.py --port 8123
uv run python kali_scan.py --url http://127.0.0.1:8123 --authorized \
  --output rapport_web.html --allow-missing
```

Options principales

Option	Effet
<code>--url URL</code>	Cible à scanner (http/https)
<code>--check</code>	Préflight (présence des outils) sans scanner
<code>--authorized</code>	Confirme l'autorisation (obligatoire pour scanner)
<code>--attack</code>	Ajoute les outils invasifs (sqlmap, xssstrike, commix, hydra)
<code>--full / --maximal</code>	Mode maximal : tout (web et attack), aucun timeout, wordlist complète, nmap -p- -sC , audit complet (JSON + HTML + PDF)
<code>--pdf</code>	Produit aussi le rapport PDF de l'audit complet
<code>--dry-run</code>	Affiche les commandes qui seraient lancées, rien n'est exécuté
<code>--tools</code> <code>nmap,nuclei</code>	Limite aux outils listés
<code>--exclude nmap</code>	Exclut des outils
<code>--output</code> <code>fichier.html</code>	Rapport écrit (sinon résumé console)
<code>--allow-missing</code>	Continuer si des outils web manquent
<code>--tool-timeout</code> <code>SECONDES</code>	Borne chaque outil (même en mode maximal), ex. <code>--tool-timeout 600</code> = 10 min/outil
<code>--verbose</code>	Détail du préflight

5. Le mode attack (que pour les cibles autorisées)

Les outils invasifs sont exclus par défaut. Ajoutez `--attack` quand vous avez l'autorisation explicite :

```
uv run python kali_scan.py --url https://example.com --authorized --attack
```

- sqlmap, xssstrike, commix tournent en mode **détection** (pas de dump / pas de destruction de données).

- hydra est **désactivé par défaut** sauf si vous fournissez des wordlists (objectif : ne jamais brute-forcer sans information préalable).
-

6. Comprendre les sorties

Chaque outil produit des **relevés** (findings) associés à la cible. Le rapport HTML affiché une **note de dette web /100** (parité avec le rapport statique), des cartes (Relevés, Critiques, À revoir, MINEUR, Outils OK), la **table par outil** (statut, durée, nombre de relevés), le **préflight** et les relevés **groupés par outil**. Le JSON reproduit la même structure (méta, résumé, findings, score).

Le **code de sortie** de `kali_scan.py` :

- `0` : aucun relevé critique/haute ;
 - `1` : au moins un relevé **critique ou haute** (utile en CI) ;
 - `2` : erreur d'usage (pas d'URL, pas d' `--authorized` , outils manquants).
-

7. Aller plus loin

- **Mode normal** (`kali_scan.py`) : wordlists **limitées** (max 200 mots) et **timeouts** par outil (120 à 480 s) pour rester raisonnable ; un outil qui timeout n'arrête pas le scan. C'est un premier passage reproductible.
- **Mode maximal** (`ironman.py` / `--full`) : **aucune limite** — wordlist complète, aucun timeout, outils poussés au maximum et audit complet en PDF. C'est la commande unique « tout l'audit ensemble ».
- Les **logs bruts** de chaque outil sont écrits dans un répertoire temporaire (`codescan-kali/TIMESTAMP/`) pour analyse manuelle.

8. Dépannage

Problème	Cause probable	Solution
2 erreur d'usage	Pas de --authorized	Ajouter --authorized
Outil «manquant » à --check	Binaire absent	<code>sudo apt-get install -y <paquet></code>
--attack n'effectue rien	hydra a besoin de wordlists	Fournir --hydra-users / --hydra-passwords
ssllscan non lancé	Cible en http	Utiliser une URL https

Rappel final : IRON MAN AI (CodeScan) est un outil de **défense**.

Ne l'utilisez que pour des sites que vous possédez ou que vous êtes autorisé à auditer. La sécurité est une histoire de confiance, pas de parcours d'outils.

Généré par CodeScan — manuel imprimable.